

Segurança da Informação

Riscos

Prof. Me. Euclides Nasorri Gottsfritz
euclides.gottsfritz@ifsp.edu.br



INSTITUTO FEDERAL
São Paulo
Campus Catanduva

Agenda



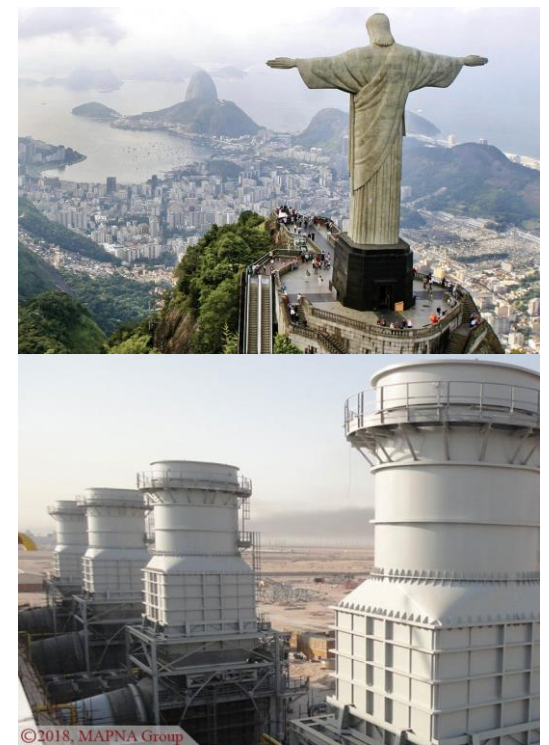
- Revisão;
- Riscos;
 - Vulnerabilidades;
 - Ameaças;
 - Impacto;
 - Medidas de Segurança;
 - As 6 Barreiras;
 - Equação do Risco;
- Considerações Finais e Referências;



Revisão

Revisão

- Vimos o que é Segurança;
 - A definição é universal, mas a aplicabilidade é local;
 - (Rio de Janeiro x Iraque).
- Vimos o que é Informação;
 - Conjunto ordenado de Dados.
- Logo, Segurança da Informação é “uma área do conhecimento dedicada a **GARANTIR** a informação contra **Acessos Não Autorizados, Alterações Indevidas e Indisponibilidades**” (SÊMOLA, 2014).
 - Ou seja, Segurança da Informação **GARANTE** a **Confidencialidade, Integridade e Disponibilidade**;

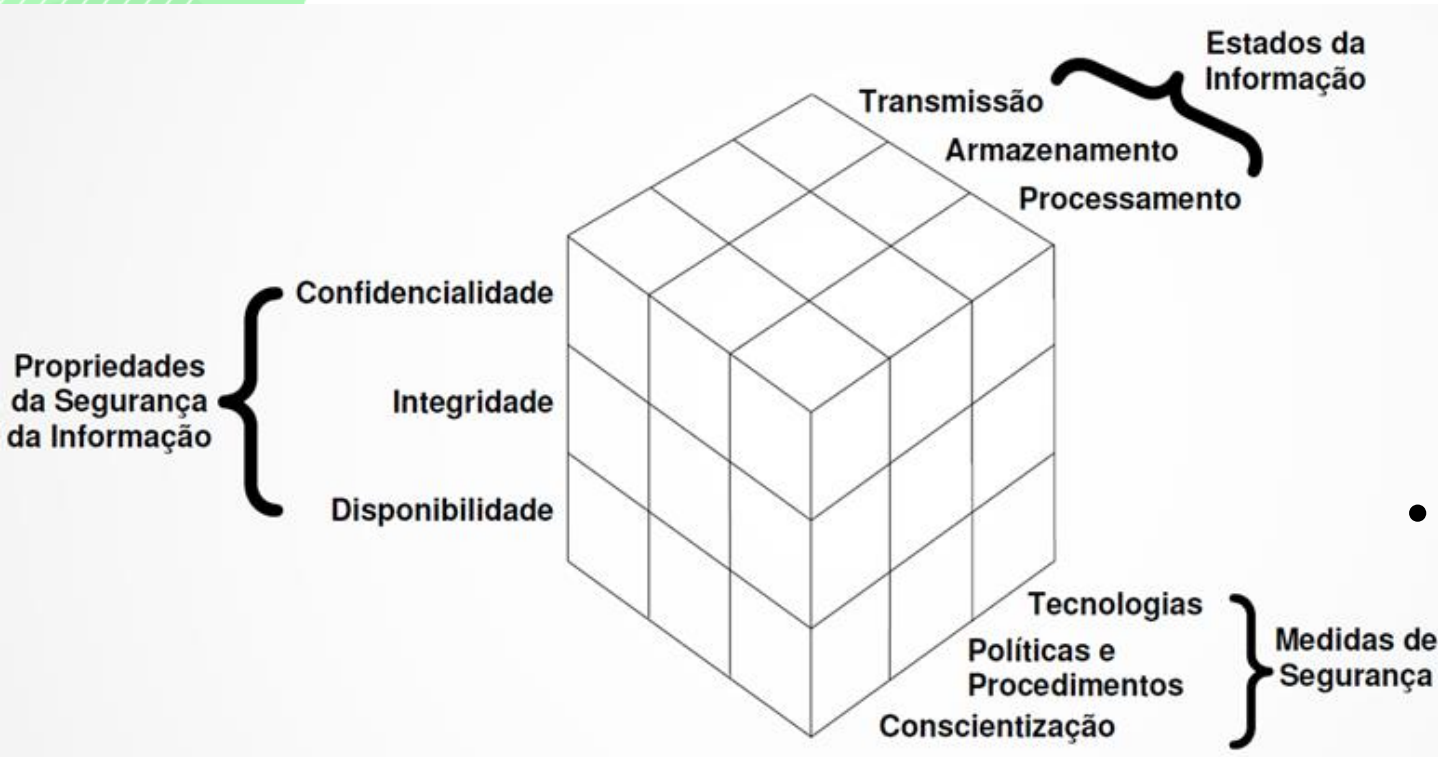


Revisão

- Vimos o que é **Dados**, **Informação**, **Conhecimento** e **Inteligência**;
- Vimos sobre os Valores da Informação;
- Vimos o que faz, e o que é necessário para ser um Profissional de S. I.;
 - Carreiras e Salários.
- Vimos que existem algumas **ISOs** que normatizam **Segurança da Informação**;
- Vimos sobre **Ativos**;
 - Ativos Primários/de Negócio, e Ativos de Suporte;
 - Necessidade de **INVENTARIAR** e **CLASSIFICAR** os Ativos;



Revisão



- Vimos os 3 estados básicos da informação;

– Transmissão, Armazenamento e Processamento.

- E as 3 Propriedades PRIMORDIAIS da Informação;

– Confidencialidade, Integridade e Disponibilidade.



Riscos

O que são Riscos?

MICHAELIS

Português

Inglês

Espanhol

Alemão

Italiano

Dicionário Brasileiro da Língua Portuguesa

Sobre o dicionário Como consultar ▾ Noções gramaticais ▾ Créditos

Português Brasileiro ▾ Digite o termo desejado

risco²

ris·co

sm

- 1 Possibilidade de perigo, que ameaça as pessoas ou o meio ambiente.
- 2 **POR EXT** Probabilidade de prejuízo ou de insucesso em determinado empreendimento, projeto, coisa etc. em razão de acontecimento incerto, que independe da vontade dos envolvidos.
- 3 **JUR** Incidente que acarreta indenização, em contratos de seguro.
- 4 **JUR** Em situação de risco, responsabilidade sobre a perda ou o dano.



INSTITUTO
FEDERAL
São Paulo

Câmpus
Catanduva

- Essas são as definições do dicionário Michaelis (2024) para “Risco”;
 - Observe a definição “2” e “4”.
- De forma geral, a **PROBABILIDADE** de **PREJUÍZO** em razão de **ALGO** ou **ALGUÉM**;
- Especificamente em S. I., podemos dizer que essa “Probabilidade” é composta por **3 Fatores** e **1 Razão**.



1º Fator - Vulnerabilidades

Vulnerabilidades



- O que é uma Vulnerabilidade?
 - Segundo a ISO 27002, é a “**Fragilidade** de um ATIVO ou grupo de ATIVOS que pode ser **explorada** por uma ou mais **Ameaças**”;
- Porém, ainda não vimos a definição de “Ameaças”, então em termos mais simples como vocês definiriam “Vulnerabilidade”?
- Qualquer **fraqueza** que possa ser utilizada para **comprometer** a segurança de **sistemas** ou **informações**;
 - Ou seja, que comprometa pelo menos 1 das 3 **Propriedades da Informação**;

Vulnerabilidades



- As **Vulnerabilidades** devem ser **Identificadas** e **Corrigidas**. Elas têm origem nas mais diversas **FONTES**:
 - **Comunicação**: abrange o tráfego de informações. **Ex**: envio de email ao remetente errado;
 - **Instalações**: são vulnerabilidades físicas. **Ex**: uma instalação elétrica feita fora do padrão;
 - **Hardware**: falhas em equipamentos. **Ex**: fonte queimada no servidor;
 - **Humanas**: erro de pessoas de dentro e fora da empresa. **Ex**: ex-funcionário que deleta informações da empresa;
 - **Mídias**: falha no armazenamento de informações. **Ex**: não ter Backup das informações vitais;
 - **Naturais**: relacionado à natureza. **Ex**: manter servidores no subsolo de uma região com alagamentos;
 - **Software**: Programas, S.Os, Banco de Dados. **Ex**: não realizar atualização crítica do S.O. do servidor.

Vulnerabilidades

- Com a finalidade de exemplificar como a **vulnerabilidade** de um **Ativo de Suporte (Hardware)** pode impactar em residências e empresas:
 - Em 2018 o FBI, alertou globalmente sobre a exploração de uma vulnerabilidade encontrada em roteadores, o Olhar Digital (2018) fez um matéria sobre:
 - “Entenda os riscos dos ataques a roteadores e saiba como se proteger”

<https://youtu.be/YIGowCmtO7U>





2º Fator - Ameaças

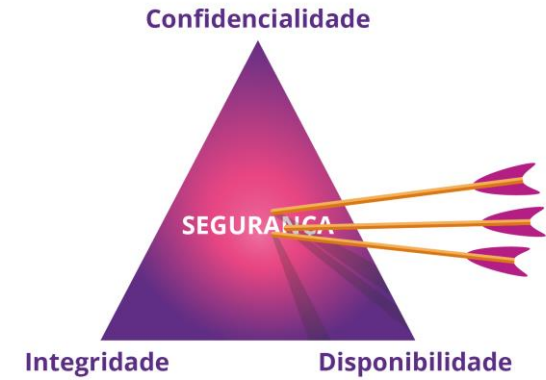
Ameaças

- O que é uma Ameaça?
 - Novamente, segundo a ISO 27002, é a “**Causa** potencial de um **incidente** indesejado, que pode resultar em **dano** para um sistema ou organização.”;
- E para vocês, o que são “Ameaças”?
 - São **Agentes** que potencialmente podem **comprometer** a **Confidencialidade**, **Integridade** e **Disponibilidade** da Informação dada as **Vulnerabilidades**;
- Mas por que “dada as vulnerabilidades”?
 - A ameaça deixa de ser uma ameaça sem vulnerabilidade, ou pela correção ou mitigação.



Ameaças

- Já que uma **Ameaça** pode comprometer a **Confidencialidade**, **Integridade** e **Disponibilidade** da Informação, podemos deduzir que não são apenas invasões de redes e computadores que são Ameaças.
 - Exemplos?
 - Indisponibilidade por **falta de energia** também é uma ameaça, mesmo ela não sendo intencional;
- Ou seja, cabe à Segurança da Informação prover mecanismos para impedir que as **Ameaças** explorem as **Vulnerabilidades**;



Ameaças

- Basicamente, existem 3 tipos de **AMEAÇAS**:
 - **Ambientais** (ou Naturais): causados por fenômenos da natureza.
Exemplos?
 - **Ex**: enchentes, vendavais, periquitos, etc.
 - **Deliberadas** (ou Intencionais): quando à intenção de causar danos. Exemplos?
 - **Ex**: sabotagem, furto, vandalismo, malware, etc.
 - **Acidentais** (ou Involuntárias): quando NÃO à intenção, comumente ocorrem por negligência. Exemplos?
 - **Ex**: acidentes, falha humana, falta de capacitação, etc.



Ameaças

Vulnerabilidade	Ameaça
Falta de treinamento de funcionários	Erros humanos
Interrupção no servidor por queima da fonte	Falha de hardware
Sistema aplicativo aceita qualquer valor nos seus campos	Falha de software
Inundação da sala em virtude das fortes chuvas	Ações da natureza
Explosão provocada intencionalmente no terminal de ônibus	Terrorismo
Máquina ATM virada e pichada	Vandalismo

Fonte: BEZERRA, ESCOLA SUPERIOR DE REDES RNP (2013)

Ameaças

- É importante notar que sem uma Vulnerabilidade, uma Ameaça não se torna um **Risco**, e vice-versa.
- Mas e se a Ameaça se concretizar, o que irá acontecer?
 - Um **IMPACTO**;





3º Fator - Impacto

Impacto

- Mas afinal, o que é um IMPACTO?
 - Segundo Sêmola (2014), é a “Abrangência (gravidade) dos **Danos** causados por um incidente de segurança sobre um ou mais **processos de negócio**.”.
- E para vocês, como pode-se definir “Impacto”?
 - **Unidade de medida** utilizada para **mensurar** os **danos causados** por um incidente de segurança;
 - Deve considerar aspectos QUALITATIVOS E QUANTITATIVOS;



Impacto

- Como exemplos de Impactos negativos, pode-se citar perdas financeiras, de confiança, paralisação de serviços, entre outros;
 - Ex: Qual o **IMPACTO** se as provas do ENEM vazarem 90 dias antes da data do exame?
 - Ex2: E se o vazamento ocorrer 48 horas antes?
- Por isso que coloquei a palavra “gravidade” na definição do Sêmola (2014), ambas as situações têm a mesma **ABRANGÊNCIA** (nacional), mas a segunda é mais **GRAVE**.



Impacto

- É importante notar que se uma Vulnerabilidade OU Ameaça não têm chances de causar Impacto à empresa, então não existe **Risco**.
- Mas então como impedir que uma **Ameaça** explore uma **Vulnerabilidade** e cause um **Impacto**?
 - Através de mecanismos de **Controle**, **Estabelecimento de Protocolos** e até mesmo a criação de **Políticas de Segurança**, para que as Vulnerabilidade não sejam exploradas e/ou as Ameaças não se concretizem.
 - Ou se preferirem, segundo Sêmola (2014), através de “**Medidas de Segurança**”.





A Razão – Medidas de Segurança

Medidas de Segurança

- “São as **práticas**, **procedimentos** e **mecanismos** usados para a **proteção da informação** e seus **ativos**, que podem **impedir** que **ameaças** explorem **vulnerabilidades**.” (SÊMOLA, 2014);
- Mas nas palavras de vocês, o que são “Medidas de Segurança”?
 - São **meios** para **eliminar** as vulnerabilidades e conseqüentemente, **neutralizar** a **Ameaça**;
- É importante notar que ao **ELIMINAR** uma vulnerabilidade, ou **REDUZIR** o seu impacto, os **Riscos** são minimizados;



Medidas de Segurança

- As Medidas de Segurança são divididas em 3 características:
 - **Preventivas:** Têm por objetivo **evitar** que incidentes de Segurança ocorram através de **mecanismos** que estabeleçam **conduta** e **ética**. **Ex:** Instruções e Procedimentos de Trabalho, Controle de Acesso, Ferramentas de Segurança (como Firewall e Antivírus), etc.
 - **Detectivas:** Visam **identificar condições** ou **agentes causadores de ameaças**, a fim de **evitar** a **exploração de vulnerabilidades**. **Ex:** Sistema de Detecção de Intrusão, Câmera de Vigilância, etc.
 - **Corretivas:** Têm por objetivo **corrigir** a estrutura tecnológica e humana para **estabelecer** as **condições de segurança** proposta pela instituição. **Ex:** Restauração de Backup, Plano de Recuperação de Desastres, etc.

Medidas de Segurança

- Importante notar que várias **medidas de Segurança** podem possuir mais de uma **característica**;
 - **Ex:** Plano de Recuperação de Desastres é uma Medida Preventiva, dada a sua existência, e uma Medida Corretiva, quando aplicada.
 - Conseguem elaborar algum outro exemplos?
- Ou seja, essa categorização demonstra apenas o foco **PRINCIPAL** do recurso analisado.



Medidas de Segurança

Vulnerabilidade	Ameaça
Falta de treinamento de funcionários	Erros humanos
Interrupção no servidor por queima da fonte	Falha de hardware
Sistema aplicativo aceita qualquer valor nos seus campos	Falha de software
Inundação da sala em virtude das fortes chuvas	Ações da natureza
Explosão provocada intencionalmente no terminal de ônibus	Terrorismo
Máquina ATM virada e pichada	Vandalismo

Fonte: BEZERRA, ESCOLA SUPERIOR DE REDES RNP (2013)

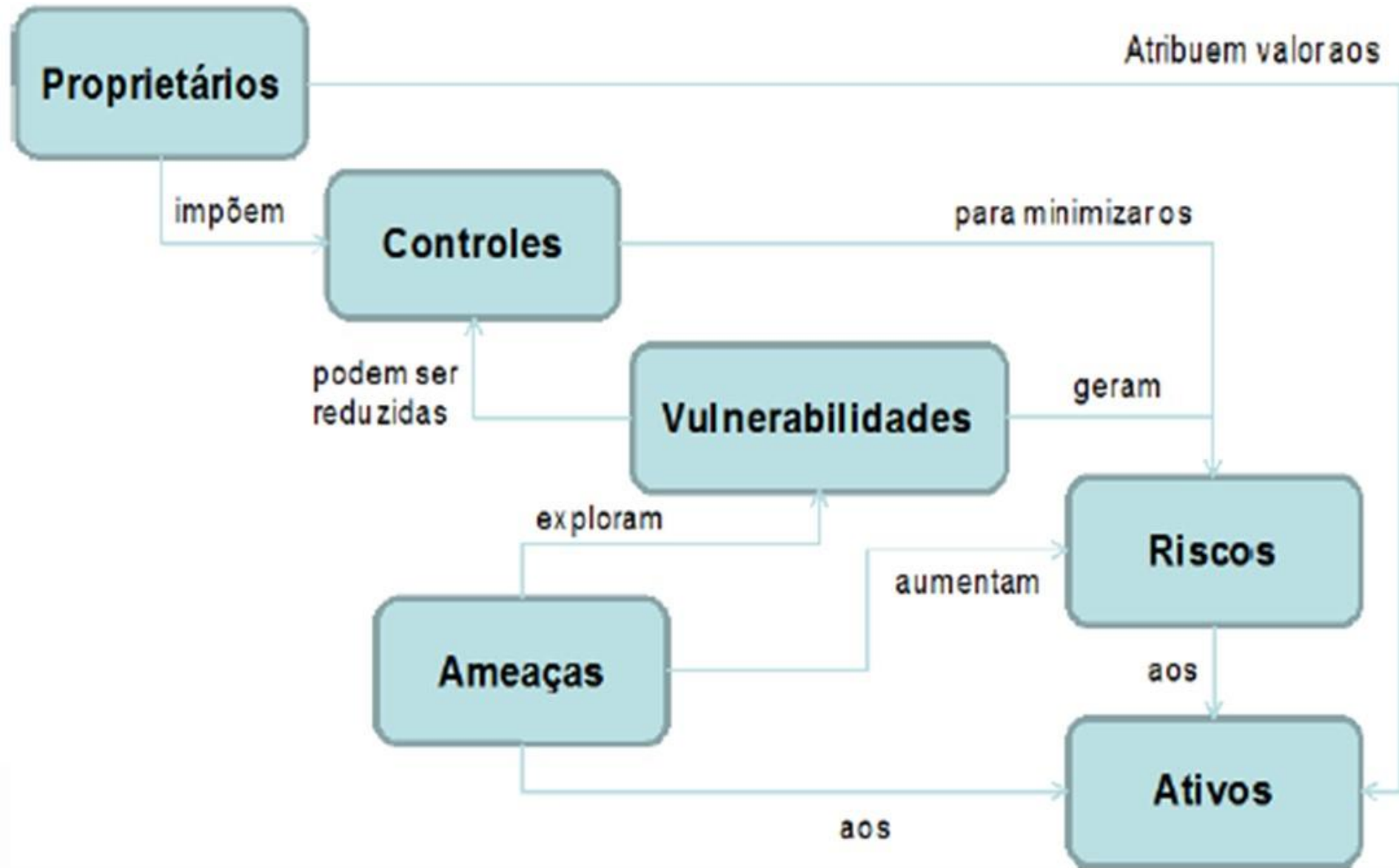
Como vocês mitigariam essas situações?

Medidas de Segurança

- Para implementação correta de Medidas de Segurança, é importante a execução de algumas etapas:
 - Classificar os **Ativos**;
 - Detectar e Prever as **Vulnerabilidades**;
 - Identificar as **Ameaças**;
 - Até concluir a **Análise de Risco** com a avaliação de **Gravidade dos Impactos** para cada situação de **Risco**.
- Com tudo isso em mãos, chegamos às **Medidas de Segurança**.
 - Para cada uma das Vulnerabilidades e Ameaças, é proposta pelo menos uma **Medida**;
 - Leva-se em conta a gravidades dos **Impactos** e o poder de **Mitigação** das **Medidas**;

		Probabilidade X Impacto		
Probabilidade	Alto (3)	3	6	9
	Médio (2)	2	4	6
	Baixo (1)	1	2	3
		Baixo (1)	Médio (2)	Alto (3)

Medidas de Segurança



Fonte: Fagundes (2012)

Medidas de Segurança

- Outro ponto, durante a análise de **Medidas de Segurança**, **NÃO** é recomendável a utilização de **Medidas Próprias**, e sim das sugeridas pela **ABNT NBR ISO/IEC** da série 27000;
- Essas normas e procedimentos foram muito **estudadas** e **trabalhas** para cobrir o maior número de aspectos, detalhes e riscos possíveis, além de serem mundialmente reconhecidas;

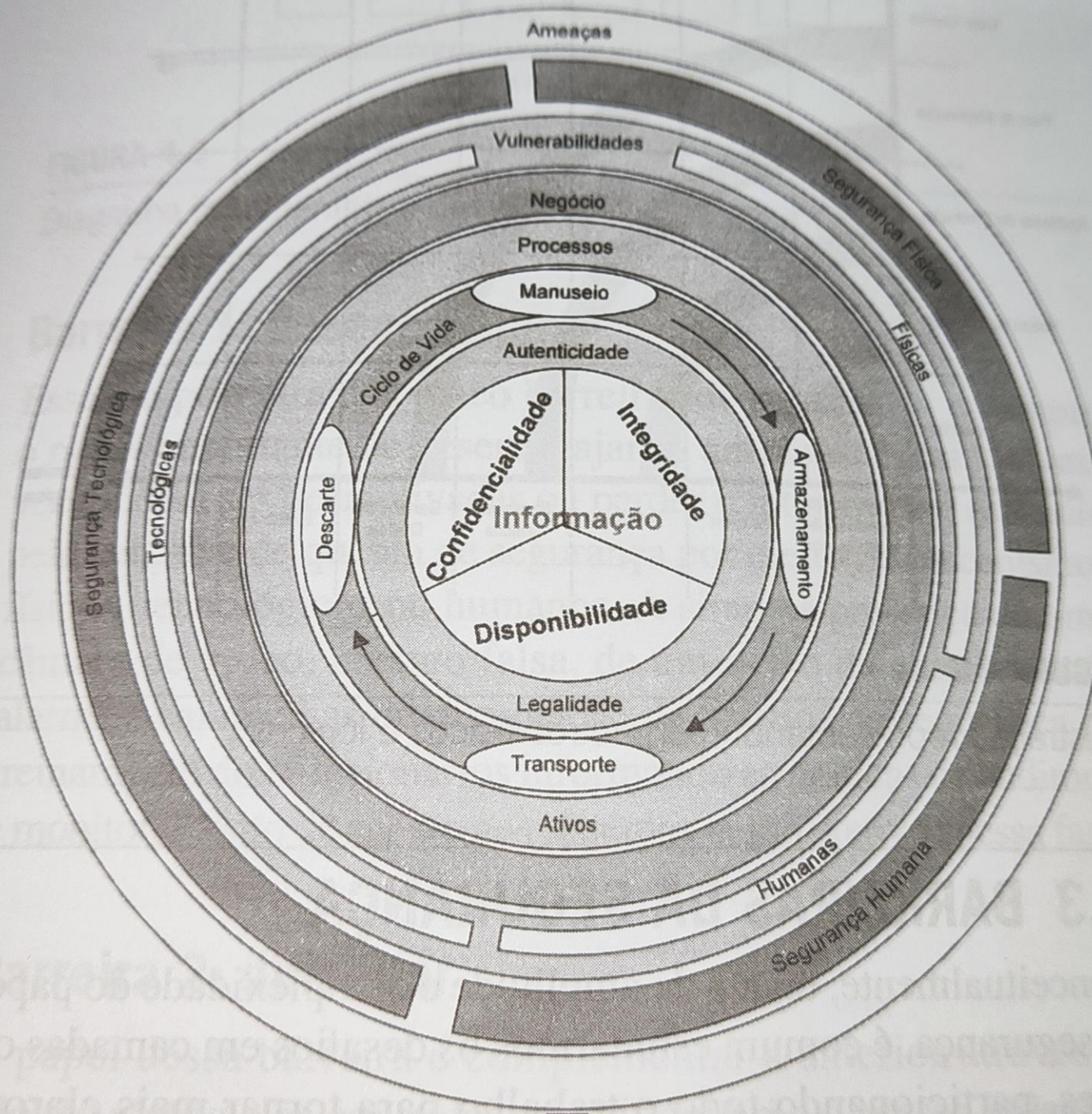


Medidas de Segurança

- É **vital** entendermos que nem sempre uma **Medida de Segurança** é implementada, isso acontece principalmente quando seus **custos** são muito **elevados**, inclusive ultrapassando o valor da perda causada pela **exploração da Vulnerabilidade**;
 - Com isso em mente, muitas das vezes **assume-se o risco** ou reduz o **impacto** (financeiro) através da contratação de um seguro por exemplo.
- Também é importante notar que os **desafios** vão muito além das **Medidas**, **Vulnerabilidades** ou **Ameaças**, como está ilustrado na imagem a seguir;



Visão Condensada dos Desafios

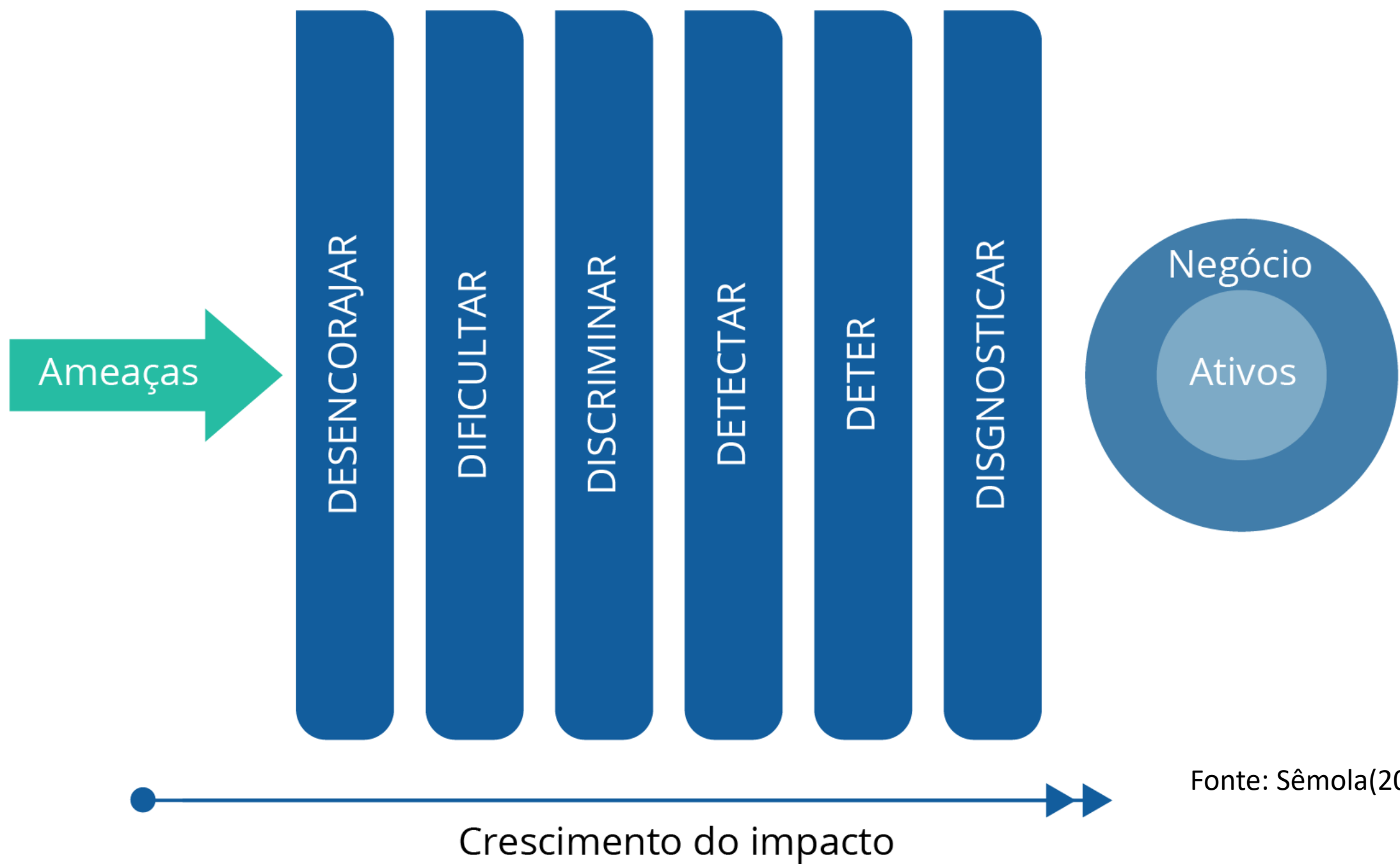


Fonte: Sêmola(2014)

Medidas de Segurança - Barreiras

- Dada a amplitude e complexidade da Segurança da Informação, Sêmola (2014) propõe que as **Medidas de Segurança** sejam estudadas em **6 diferentes Barreiras**;
- Todas tem o objetivo de **reduzir os Riscos**, mas devem **estar perfeitamente Integradas para esse objetivo**;

AMEAÇAS	
1ª BARREIRA	DESENCORAJAR
2ª BARREIRA	DIFICULTAR
3ª BARREIRA	DISCRIMINAR
4ª BARREIRA	DETECTAR
5ª BARREIRA	DETER
6ª BARREIRA	DIAGNOSTICAR
ATIVOS	



Medidas de Segurança - Barreiras

- Barreira 1 – **DESENCORAJAR**;
 - Cumpre o papel de desencorajar ameaças;
 - Tende a implementar **mecanismos físicos**, **lógicos** ou **humanos** que irão desmotivar a realização da **quebra de segurança**;
 - **Ex**: Presença de câmera de vigilância ou aviso de existência de alarme, mesmo que falsa, em frente a um imóvel irá desencorajar furtos e roubos no local;
 - **Ex**: Divulgação de Políticas de Segurança ou informe sobre práticas de auditoria durante treinamento de novos funcionários, irá desencorajar a quebra de protocolos de segurança;



Medidas de Segurança - Barreiras



- Barreira 2 – **DIFICULTAR**;
 - Complementarmente à Barreira anterior, a 2ª Barreira irá implementar **controles** que dificultarão o acesso indevido;
 - **Exemplo de Dispositivos Físicos:** Detectores de Metal, Roletas, Alarmes ,etc;
 - **Exemplo de Dispositivos Lógicos:** Leitor Biométrico, Senhas, Certificado Digital, Firewall, etc;

Medidas de Segurança - Barreiras

- Barreira 3 – **DISCRIMINAR**;
 - Essa barreira é a que **Identifica** e **Gerencia** os acessos através da definição de perfis e autorização de permissões;
 - Os sistemas são empregados para **monitorar** e estabelecer os mais diversos **limites**, como acesso ao serviço de telefonia, acesso físico a departamentos e até mesmo a softwares e bancos de Dados;
 - **Ex:** Avaliação do uso de E-mail, gestão de acesso à ambientes físicos, etc.



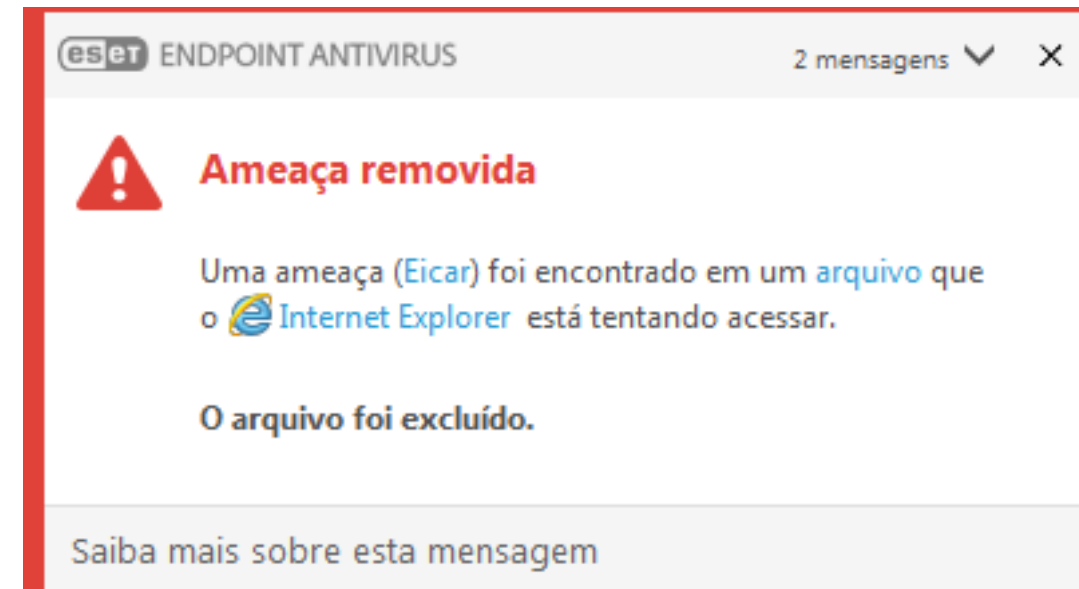
Medidas de Segurança - Barreiras



- Barreira 4 – **DETECTAR**;
 - Complementar às anteriores, essa barreira irá **detectar** as várias formas de acesso não autorizado, e até mesmo **infecção por vírus** ou **descumprimento de normas** de segurança;
 - Ou seja, é composta por **sistemas capazes de realizarem essas detecções**, preferencialmente de forma automatizada, para que o tempo de resposta seja o menor possível;
 - **Ex:** Sistemas de Detecção de Intrusão, Antivírus, etc;

Medidas de Segurança - Barreiras

- Barreira 5 – **DETER**;
 - Essa barreira tem o objetivo de **Deter** a **Ameaça** para que ela não atinja os **Ativos da Empresa**;
 - O acionamento dos mecanismos de controle deve **Conter** a **falha de segurança**;
 - Porém, também significa que todas as outras 4 Barreiras falharam em seus papéis;
 - **Ex:** Ações Administrativas, Bloqueio de Acessos físicos e lógicos, etc;



Medidas de Segurança - Barreiras

- Barreira 6 – **DIAGNOSTICAR**;
 - Apesar de ser a última Barreira, ela representa a **continuidade** do processo de **Gestão da Segurança da Informação**;
 - Ela se **conecta** diretamente com a **1ª Barreira**, já que o Diagnóstico do ocorrido pode implicar em melhorias em todas as barreiras anteriores, a partir da Primeira;
 - Deve ser **conduzida com cuidado** e sempre considerar os **aspectos tecnológicos, físicos e humanos**, além de estar sempre orientado às necessidades e características dos processos de **Negócio da Empresa**;



Medidas de Segurança - Barreiras

- Barreira 6 – **DIAGNOSTICAR**;
 - Caso o processo de Diagnóstico for **mal conduzido**, sem instrumentos ou metodologia, poderá distorcer o real entendimento da situação de **Segurança**;
 - Com o entendimento **distorcido**, existe a probabilidade de se **dimensionar erroneamente** as barreiras ou empregar recursos de forma **desproporcional, redundante** e ineficaz para a melhoria de **soluções de Segurança**;
 - Logo, o retorno sobre os investimento será abaixo do esperado o que acarretará em um nível de segurança abaixo do prometido e, por vezes, aquém das necessidades da Empresa;



Equação do Risco

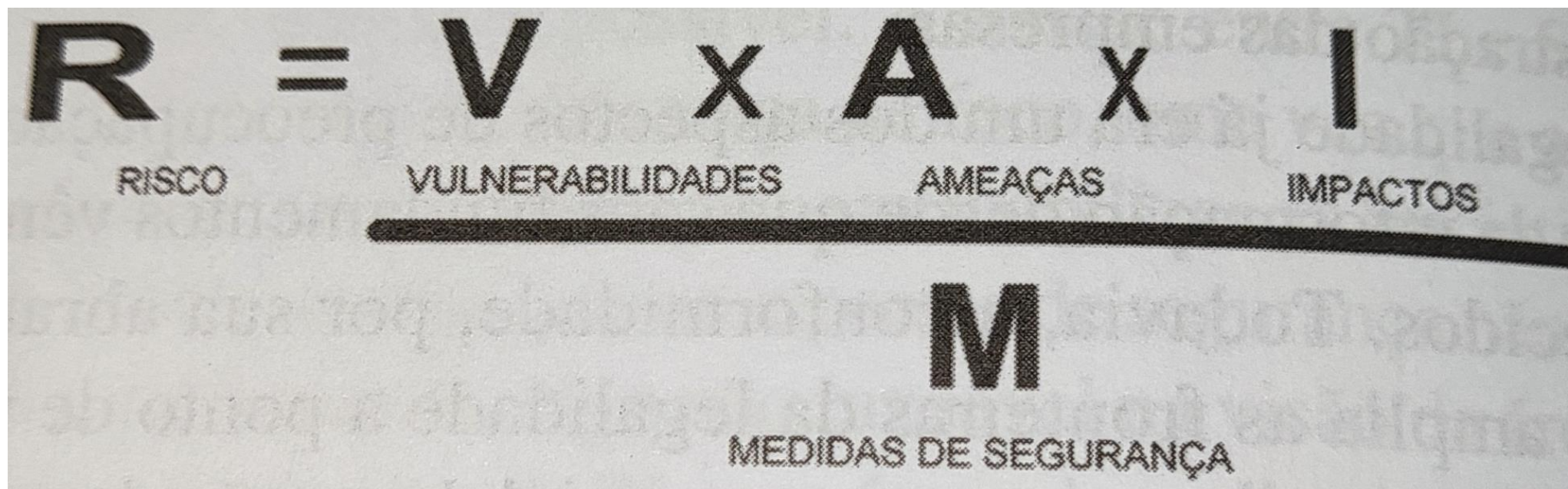
Equação do Risco

- De forma geral, sabemos que **Risco** é a PROBABILIDADE de PREJUÍZO em razão de ALGO ou ALGUÉM (Slide 8);
- De forma específica, para Sêmola (2014) “**Risco** é a probabilidade de que agentes, que são **Ameaças**, explorem **Vulnerabilidades**, expondo **Ativos** a perdas de confiança, integridade e disponibilidade, e causando **Impactos** nos negócios.”
 - Adicionalmente, “Esses **Impactos** são limitados por **Medidas de Segurança** que protegem os **Ativos**, impedindo que **Ameaças** explorem **Vulnerabilidades**, diminuindo o **Risco**.”.



Equação do Risco

- Dadas as informações e definições, Sêmola(2014) expõe a seguinte equação para mensurar o Risco;



The diagram illustrates the Risk Equation as a mathematical formula. It features large, bold letters for the variables and smaller text for their definitions. The equation is structured as follows:

$$R = V \times A \times I \div M$$

Below the letters, the corresponding terms are listed:

- R** is labeled **RISCO**.
- V** is labeled **VULNERABILIDADES**.
- A** is labeled **AMEAÇAS**.
- I** is labeled **IMPACTOS**.
- M** is labeled **MEDIDAS DE SEGURANÇA**.

A horizontal line is drawn under the terms VULNERABILIDADES, AMEAÇAS, and IMPACTOS, indicating that these three components are multiplied together and then the result is divided by MEDIDAS DE SEGURANÇA.

Equação do Risco



- É importante notar que SE não tivermos **Vulnerabilidade**, não temos **Risco**;
- O mesmo vale para as **Ameaças** e os **Impactos**;
 - Qual o **Risco** de uma **Vulnerabilidade** que não causa impacto **NENHUM** para a empresa?
- Também vale notar que pelas **Medidas de Segurança** serem FATOR na Equação, por maiores que sejam as Medidas e menores que sejam as **Vulnerabilidade**, **Ameaças** e **Impactos**, o Risco tenderá a 0 mas **NUNCA** será 0;
- É preciso entender que existem **Riscos Desconhecidos**, e que as **Ameaças Deliberadas** sempre procuram maneiras de contornar as **Medidas de Segurança**;

Equação do Risco

- Riscos, Ameaças e Vulnerabilidades em Segurança da Informação
- https://www.youtube.com/watch?v=zD3M_EqkVFg&t





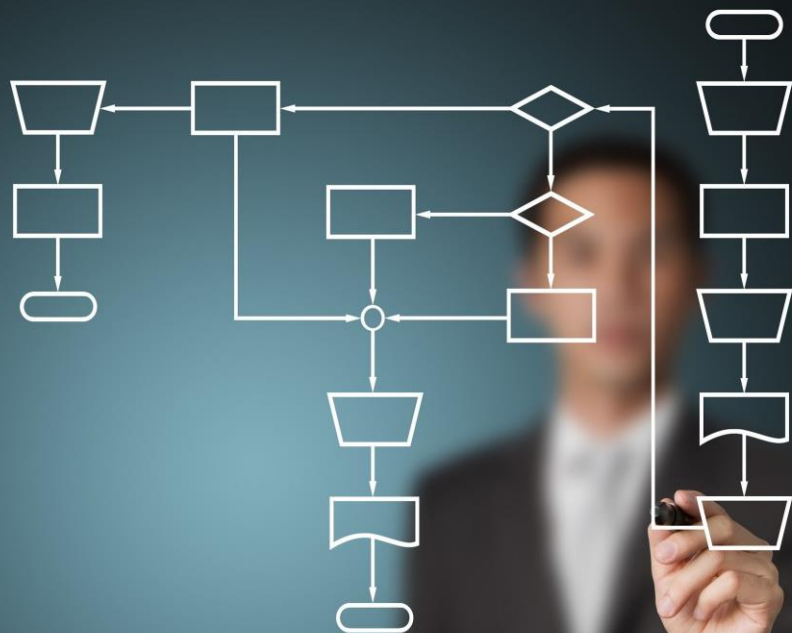
Considerações Finais

Considerações Finais



- Precisamos ter em mente que os **agentes**, normalmente do lado de fora da empresa, irão buscar formas de **contornar as Barreiras** de Segurança e **Explorar as Vulnerabilidades**;
- Logo, a primeira etapa de qualquer projeto de segurança é **entender a empresa**;

Considerações Finais



- Devemos ter conhecimento do **ambiente e processos**, dos níveis de **Controle** implementados, além de avaliar o **índice de Riscos** para que possamos sugerir **mudanças na cultura** da empresa, mesmo que sofremos com **resistência** para isso;
- A **segurança da Informação** só pode ser obtida a partir da implementação de um **conjunto de controles** adequados às **necessidades da empresa**;

Considerações Finais



Família 27000

- Esses **controles** precisam ser **estabelecidos**, **implementados**, **monitorados**, **analisados** e **melhorados**, para garantir que os **objetivos do negócio** e de **segurança** sejam atendidos;
- Também é importante conhecer as **legislações** e **normatizações**, como por exemplo a LGPD e as ISOs da série 27000 (27001, 27002 e 27005);

Referências

- ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. Segurança da informação, segurança cibernética e proteção à privacidade - Sistemas de gestão da segurança da informação – Requisitos -- **ABNT ISO/IEC 27001**. Rio de Janeiro: ABNT, 2022. Corrigida: 2023 23 f. ISBN 978-85-07-09422-7
- ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. Segurança da informação, segurança cibernética e proteção à privacidade - Controles de segurança da informação -- **ABNT ISO/IEC 27002**. Rio de Janeiro: ABNT, 2022. 191 f. ISBN 978-85-07-09276-6.
- ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. Segurança da informação, segurança cibernética e proteção à privacidade — Orientações para gestão de riscos de segurança da informação -- **ABNT ISO/IEC 27005**. Rio de Janeiro: ABNT, 2023. 75 f. ISBN 978-85-07-09650-4.

Referências

- Bezerra, Edson Kowask. **Gestão de Riscos de TI**. NBR 27005. Escola Superior de Redes RNP. Rio de Janeiro: Escola Superior de Redes, 2013.
- **Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil**, CERT.br. Cartilha de Segurança para Internet. 2 ed. Comitê Gestor da Internet no Brasil: São Paulo, 2012. Disponível em: <<https://cartilha.cert.br/livro/>>.
- Fagundes, Leonardo Lemes. **Gestão da Segurança da Informação**. UNISINOS, 2012.
- SÊMOLA, M. **Gestão da Segurança da Informação**: uma visão Executiva. Rio de Janeiro: 2. ed. Campus, 2014.

